

1. OVERVIEW

An overview of Requirement 2 (“No Defaults”), and its sub-requirements.



REQ. 2: NO DEFAULTS

REQ. 2: NO DEFAULTS

OVERVIEW

Requirement 2 (Apply Secure Configurations to All System Components) is all about minimizing vulnerabilities by eliminating obvious ones. Not having unsafe configurations;

- Basically, we assume everything by default is unsafe, so we have to change these defaults;

This requirement focuses mostly on:

- Changing default configurations, which in many cases contain vulnerabilities;
- Closing unnecessary ports, accounts, services, and other “sitting ducks” in terms of vulnerabilities;
- Changing the default passwords on devices;
- Removing or minimizing services that can be abused by attackers;

REQ. 2: NO DEFAULTS

OVERVIEW

The sub-requirements for this requirement include:

- 2.1 Processes and mechanisms for applying secure configurations to all system components are defined and understood.
- 2.2 System components are configured and managed securely.
- 2.3 Wireless environments are configured and managed securely.





REQ. 2: NO DEFAULTS

REQ. 2: NO DEFAULTS **OVERVIEW**

2.1 Processes and mechanisms for applying secure configurations to all system components are defined and understood

- This is our usual sub-requirement. So, everything we do in terms of secure configurations must be documented, updated, put to use, and all roles and responsibilities must be documented and acknowledge;

This is usually tested through:

- Examining the documentation and interviewing people to ensure that the processes are clear;
- Ensuring that the roles and responsibilities are clearly defined, as well as interviewing people to validate this;

REQ. 2: NO DEFAULTS

OVERVIEW

2.2 System components are configured and managed securely

- Essentially, this sub-requirement is about changing default vendor passwords, removing unneeded admin accounts or increasing their security (“admin”, “guest”), removing unneeded functions / services / protocols in devices, and configuring systems to use secure parameters;
- Configurations must also be secure, and admin access that is not in-person (console) must be strongly encrypted (never plaintext protocols such as telnet/HTTP);

This is usually tested through:

- Examining documentation and interviewing system administrators to ensure defaults are removed, secure configurations are applied, and security is increased;





REQ. 2: NO DEFAULTS

REQ. 2: NO DEFAULTS **OVERVIEW**

2.3 Wireless environments are configured and managed securely

- Very similar, but for wireless networks. Essentially, changing vendor defaults when installing APs or network equipment. Changing wireless encryption keys, passwords, and other defaults on these devices;
- Also rotating encryption keys when personnel that knows them leaves or when the key is compromised;

This is usually tested through:

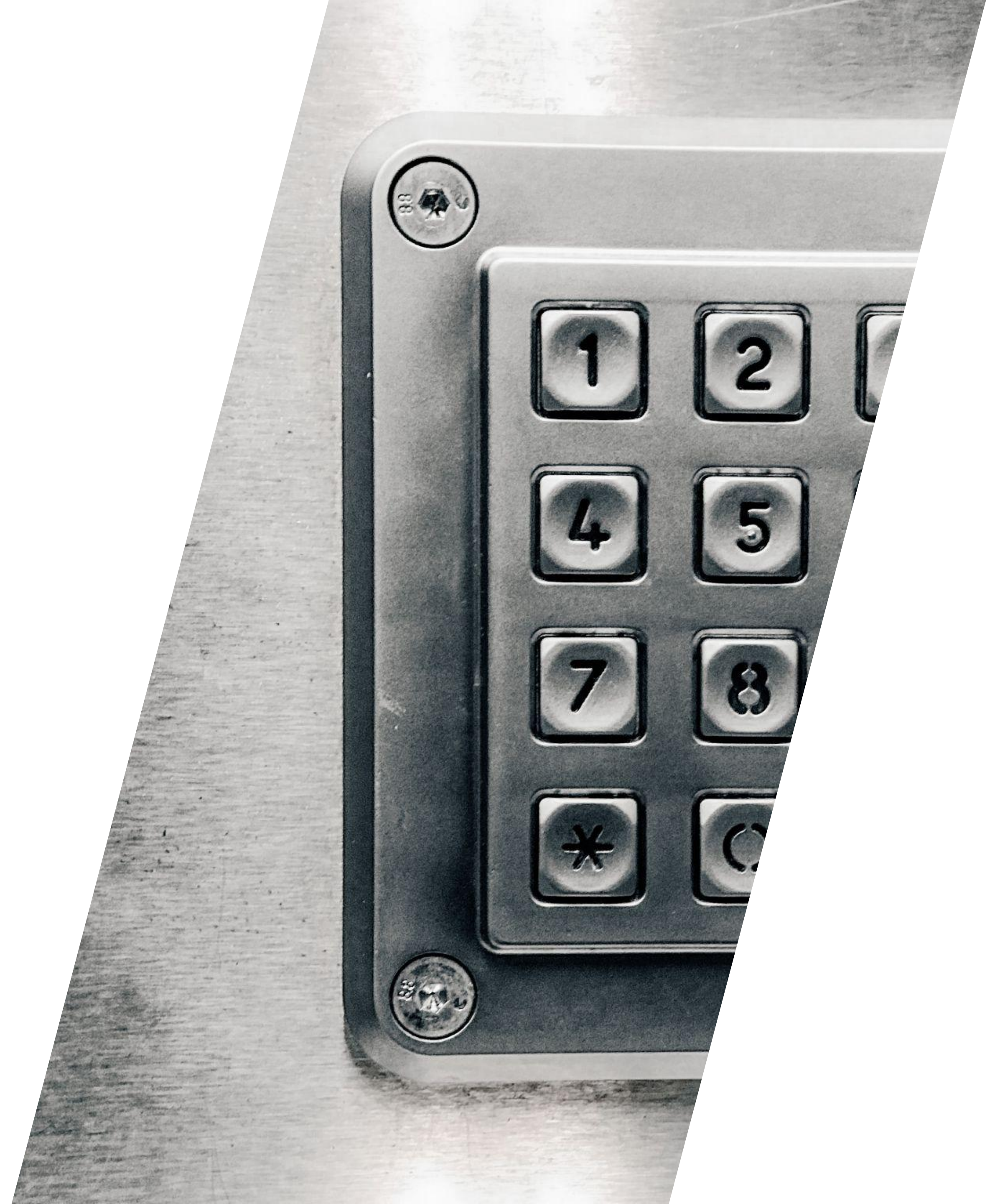
- Similarly to the previous sub-requirement, examining documentation such as configuration standards, records of configurations, and interviewing system administrators;

REQ. 2: NO DEFAULTS

OVERVIEW

How can we summarize, then, this requirement?

- Basically, it's about removing or securing existing vulnerabilities that come, by default, with systems;
- We either remove or secure accounts, services, protocols, daemons and more. Each one must have a justified business reason for existing, or we don't have it. Period;
- There are two sub-requirements relating to "general" system components, and to wireless equipment. But the logic is very much the same. The defaults of one type of system may not be the same as the defaults for the other type, but the logic remains - remove or secure anything that is a vulnerability by default;
- The goal is, again, to remove "obvious vulnerabilities";



REQ. 2: NO DEFAULTS

OVERVIEW

EXAMPLES

/01 SECURITY LEVELS

Although the ideal is one function per server, the second best-case scenario is functions with similar security levels. E.g., no DB + AD, but AD + DNS is fine.

/02 INVENTORY AS PROXY

Although asset inventorying is important, in this case the focus is on the asset inventory itself. It's a signal. If you know your assets, you're likely protecting them.

/03 “WHAT IF THEY GET IN?”

A great way to think about admin access encryption is to think, “What if an attacker got in the network?”. As for many principles, this informs you how to act.

REQ. 2: NO DEFAULTS

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization changes default passwords on all PoS systems and disables the admin account on these;
- The organization keeps all software and firmware, on all devices, updated to prevent vulnerabilities;
- The organization configures all Wi-Fi networks with strong encryption (WPA3), and changes default SSIDs;

E-COMMERCE STORE

- The organization applies secure configuration guidelines to web and database servers, disabling unnecessary services/ports;
- The organization removes all default accounts, sample files and unnecessary functionalities from web applications used;
- The organization adopts a formal patching process;

HOTEL CHAIN

- The organization develops a secure configuration baseline for all systems in all hotels, removing guest accounts and changing passwords for all of these;
- The organization identifies and disables all insecure services and protocols, such as Telnet and FTP, across all systems even remotely near the CDE;

PAYMENT PROCESSOR

- The organization establishes detailed secure configuration standards for all systems, including network devices, servers, and apps involving in payment processing for clients;
- The organization also uses configuration mgmt. (CM) tools to inventory, manage and enforce secure configs.;

REQ. 2: NO DEFAULTS

OVERVIEW

TAKEAWAYS

/01 REMOVING THE OBVIOUS

This requirement is, essentially, about removing obvious vulnerabilities that are just going to hurt you. Removing defaults, unneeded accounts, elements, etc

/03 2.2 SECURE SYSTEMS

We must change default passwords, as well as remove or secure default accounts. And all services, protocols or daemons not needed must be shut down.

/02 2.1 PROCESSES DEFINED

The usual sub-requirement. All processes and procedures must be documented and enforced, and all roles/responsibilities defined and acknowledged.

/04 2.3 SECURE WIRELESS

The same for wireless equipment. Default unsecure configurations, default AP passwords and others must be changed to protect against vulnerabilities.